

Frigoglass RPD — Deployment, Migration & Security Questions

ayush39roy@gmail.com

September 1, 2026

CONTENTS

Questions for Frigoglass — Deployment, Migration, Solution & Security

1. Deployment & Migration

2. Solution — Priority Matrix & Open Questions

3. Security

Questions for Frigoglass — Deployment, Migration, Solution & Security

Purpose: questions to put to Frigoglass ahead of / during early delivery, covering (1) how the tech stack gets deployed on their infrastructure and what migration is needed, (2) solution behaviour questions tied to the priority matrix and scheduling engine, and (3) security — both what we need to ask them and what we're already building in, so they know it's covered.

This is a client-communication document, separate from `docs/OPEN_QUESTIONS.md` (the internal engineering contract those questions are sourced from). Section 2 below restates the relevant items from there in client-facing language;

`docs/OPEN_QUESTIONS.md` remains the authoritative, numbered source of truth for engineering defaults and blocking status.

1. Deployment & Migration

Infrastructure

- What's the target hardware/VM spec (CPU/RAM/disk) for the Docker Compose host(s)? Single host, or should `solver-worker` (runs the scheduling engine) sit on a separate box for resource isolation?
- What OS/virtualization platform (VMware, Hyper-V, bare metal Linux)? Can Docker Engine + Compose be installed, or is there an internal approval process for new software on your servers?
- Which environments do you want provisioned — dev/staging/prod, or production only, with us maintaining a separate reference environment on our side?
- Expected data volume over the first 1–2 years (Postgres: ~236 active projects plus version history; MinIO: exports, attachments, snapshots) so we size storage correctly up front.

Network & access

- Internal DNS name and network zone for the app? Any firewall rules or VLAN changes needed (inbound 443, outbound to your IdP)?
- TLS certificates: internal CA issuance, or a public certificate? (Public CAs like Let's Encrypt won't reach a host behind your firewall.)
- VPN/bastion access for our team during initial deployment and any agreed post-go-live support window?

Identity

- Confirm Microsoft Entra ID as the identity provider — can we get an app registration and test-tenant client credentials before SSO integration starts?
- Is user/role provisioning driven by Entra AD groups (auto-synced), or will Frigoglass admins manage roles manually inside the app?

Migration

- Is the existing spreadsheet the system of record during transition, and is there a planned cutover date after which it's retired? Our default assumption is a one-way export only (no round-trip import) for v1 — confirm that's acceptable.
- Should historical (past/completed) project data be migrated in, or does the app start clean at go-live with only currently active projects?
- Backup/DR: our default is nightly `pg_dump` to object storage — does this need to integrate with your existing on-prem backup/retention process? Is a restore drill required before go-live?
- Who owns ongoing patching and updates after launch — your IT team pulling new versions, or a support arrangement with us?

2. Solution — Priority Matrix & Open Questions

These are running on provisional defaults today and need real answers from you to lock in final behaviour (full detail and current defaults: `docs/OPEN_QUESTIONS.md`):

- **Workflow structure** — Are the 14 workflow steps strictly sequential, or is there a real precedence structure with parallel branches?

- **FTE handling** — Should a 0.5 FTE engineer be treated as half-speed (steps take longer) or as having half the available weeks? We currently do not apply FTE to scheduling at all — confirm if that matches your intent.
 - **Chamber capacity** — Should a chamber's `efficiency` and `weeks_per_chamber` fields actually constrain lab booking, or are they for reporting/display only?
 - **Working calendars** — Do Greek, Indian, and Romanian holiday calendars need to reduce effective weekly capacity per hub, or is a uniform week acceptable for v1?
 - **Delay propagation** — When a step is delayed, should it push out every downstream step in that project, or stay a one-time adjustment applied only at the end?
 - **Planning horizon** — The Gantt display implies a 2026–2027 range (~104 weeks) but scheduling logic caps at 78 weeks. Which is correct?
 - **Priority matrix scoring** — Please confirm the current 13-dimension scoring model (Strategic Alignment, Regulatory & Quality, Financial Return, Market & Volume, Investment & Feasibility — 280 total weight, bands at $\geq 70\% \rightarrow P1$, $\geq 55\% \rightarrow P2$, $\geq 40\% \rightarrow P3$, else $P4$) is still your intended model. Who owns updating these scores, and how often (per-project, quarterly re-scoring)?
 - **Hard gates** — We currently force a project to P1 regardless of score for three conditions: regulatory deadline within 6 months, customer certification at risk (Coke/Pepsi), active safety non-compliance. Is this list exhaustive, or are there other conditions that should force P1?
 - **Optimizer trade-off** — When the automated scheduler can't fit every P1 project within the year, should it be allowed to drop a customer-certification-at-risk P1 project entirely to improve overall portfolio throughput, or should P1/hard-gated projects always be scheduled even at the cost of overall throughput? This needs an answer before the optimizer is wired into a user-facing "Auto-assign" action.
-

3. Security

Questions for Frigoglass

- Is per-engineer utilization data (who's assigned to what, at what load) GDPR personal data under your policy for EU staff (Greece, Romania)? We need your DPO's determination before shipping any screen showing named-engineer workload — this is currently a hard blocker for that part of the build.

- Is there an existing compliance framework we should align to (ISO 27001, internal InfoSec policy, vendor security questionnaire)?
- Data residency — does data from the Indian and Romanian hubs need to physically stay in-region, or is a single hosted instance acceptable regardless of physical location?
- Do you require a penetration test or formal security sign-off before go-live, and if so, who runs it — your team, us, or a third party?
- For financial fields (TCOGS, gross margin, selling price, customer name): is “encrypted at rest, never logged” sufficient, or do you need additional handling (e.g., masked in the UI for certain roles)?

What we’re already building in (so you know this is covered)

- Single sign-on via your corporate identity provider (OIDC/Entra ID) — no separate password store for this app.
- Role-based access control with row-level hub scoping enforced server-side, in the data layer — not just hidden in the UI. A Hub Planner cannot retrieve data for a hub outside their scope even via a direct API call.
- Immutable, append-only audit log of every data change — who changed what, and when.
- TLS 1.3 and HSTS at the edge, plus a web application firewall (ModSecurity + OWASP Core Rule Set) in front of the app.
- Financial fields (TCOGS, gross margin, selling price, customer name) encrypted at rest and excluded from application logs.
- No secrets committed to source control — managed via Vault or Docker secrets.
- Secure-coding baseline: no raw SQL string interpolation (parameterized queries only), no unsafe HTML injection in the frontend.
- Nightly encrypted backups, designed to integrate with your existing on-prem backup process.